

Security by design



How I am

RTDB at Netgroup (<https://netgroup.polito.it/>) -> Associate Prof. from 1 November

Contact:

- **Email:** Fulvio.valenza [at] polito [dot] it **(for official request)**
- **Telegram:** @fulvio.valenza **(for simple or urgent topics)**

Courses:

- **Networks and cloud security**
 - 1st Year, 1st + 2nd Semester
- **Data protection, privacy and anonymity**
 - 2nd Year, 1st Semester (characterizing course for Cyber Designer tracks)
- **Threat Intelligence and Incident Management,**
 - 2nd Year, 2nd Semester (characterizing course for Cyber Analyst tracks)

My role in CdLM:

- Deputy Advisor, Appraisal, Evaluation of Study Plans, Tutor



Something extra



Main Security Principles

- Security by design
- Zero Trust
- Open Design DesignPrinciple



Security by design

- Secure by design, in software engineering, means that the software has been designed from the foundation to be secure.
 - the best security tactics and patterns are selected and enforced by the architecture design, and then used as guiding principles for developers
- In cloud Computing one key aspect is the Protection of Sensitive (i.e., business critical) Data

The Protection of Information in Computer Systems

JEROME H. SALTZER, SENIOR MEMBER, IEEE, AND MICHAEL D. SCHROEDER, MEMBER, IEEE

Invited Paper



Security by design

- ✓ Least Privilege
- 🔗 Separation of Duties
- 🔗 Separation of privilege
- 🔒 Defense in Depth
- ✗ Fail Secure
- 🤝 Complete Mediation
- 🧠 Psychological Acceptability
- 🔗 Weakest Link



Least Privilege

- The principle of least privilege maintains that an individual, process, or other type of entity should be given the minimum privileges and resources for the minimum period of time required to complete a task.
- This approach reduces the opportunity for unauthorized access to sensitive information.

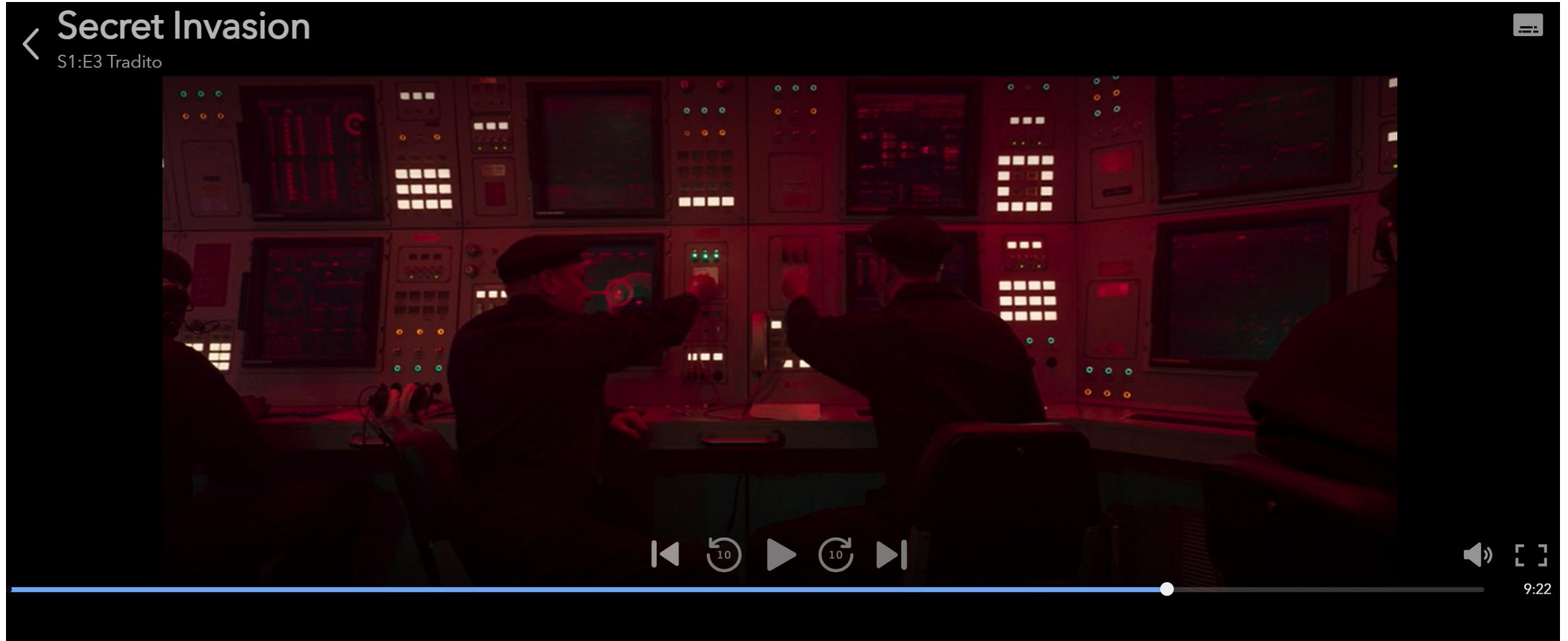


Separation of Duties

- Separation of duties requires that completion of a specified sensitive activity or access to sensitive objects is dependent on the satisfaction of a plurality of conditions.
- For example, an authorization would require signatures of more than one individual, or the arming of a weapons system would require two individuals with different keys.
- Separation of duties forces collusion among entities in order to compromise the system.



Separation of Duties (example)



Separation of Duties (example)



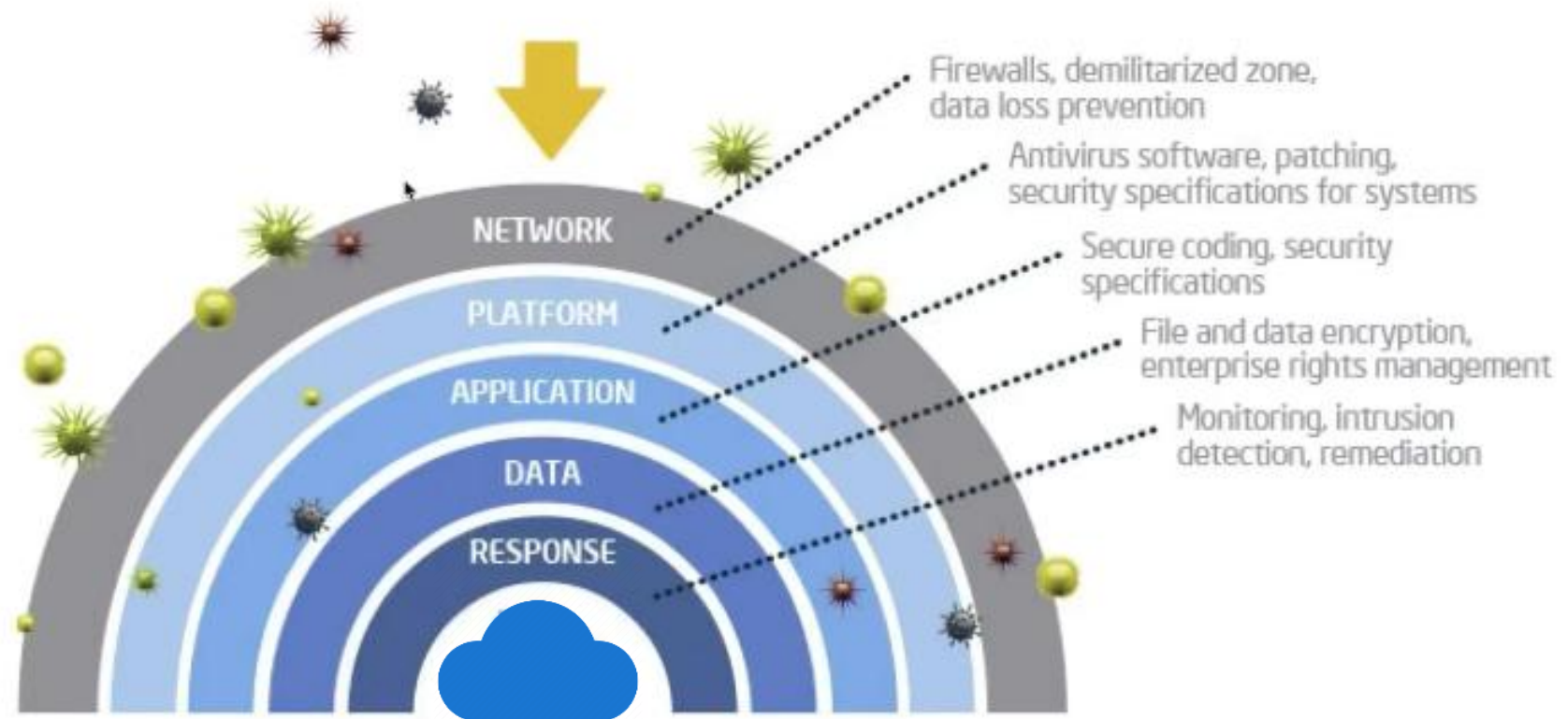
Separation of privilege

- The principle of *separation of privilege* suggests to break a single privilege among multiple independent subjects (component or user) so that more than one authorizations are required to perform an action.
- This protects the system from someone's evil intention.



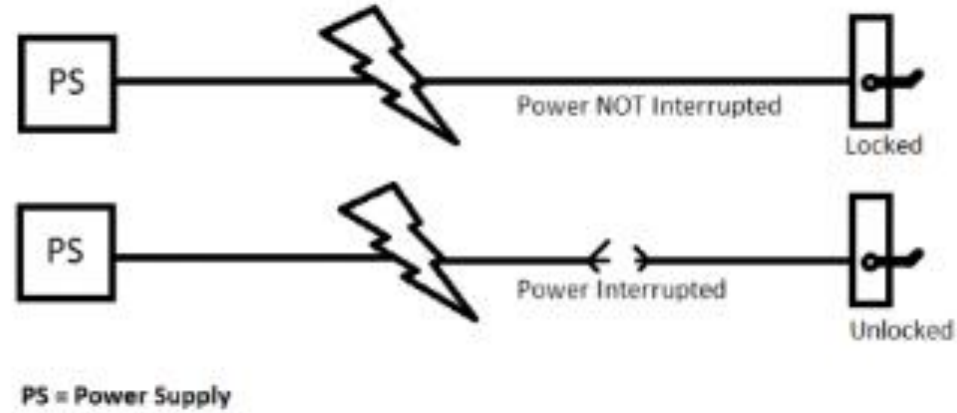
Defense in Depth

- Defense in depth is the application of multiple layers of protection wherein a subsequent layer will provide protection if a previous layer is breached.

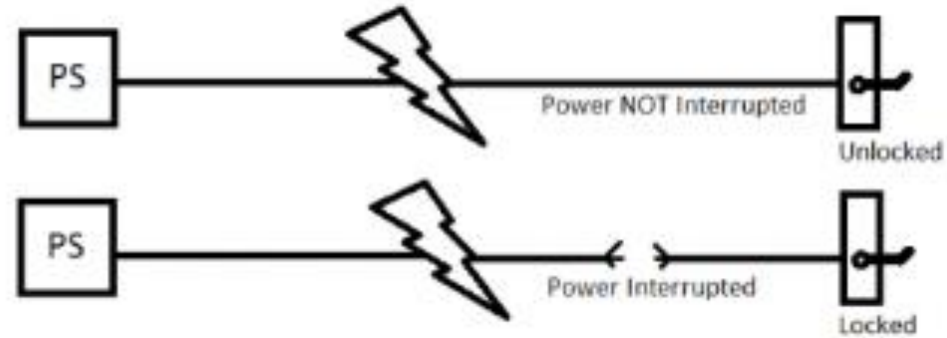


Fail Secure V.S Fail Safe

Fail Safe



Fail Secure



Fail Secure

- Fail secure means that if a cloud system fails it should fail to a state in which the security of the system and its data are not compromised.
- One implementation of this philosophy would be to make a system default to a state in which a user or process is denied access to the system.
- A complementary rule would be to ensure that when the system recovers, it should recover to a secure state and not permit unauthorized access to sensitive information.



Fail Secure

- This approach is based on using permissions instead of exclusions.
- In the situation where system recovery is not done automatically, the failed system should permit access only by the system administrator and not by other users, until security controls are reestablished.



Complete Mediation

- In complete mediation, every request by a subject to access an object in a computer system must undergo a valid and effective authorization procedure
- This mediation must not be suspended or become capable of being bypassed, even when the information system is being initialized, undergoing shutdown, being restarted, or is in maintenance mode.



Complete Mediation

Complete mediation entails the following:

1. Identification of the entity making the access request
2. Verification that the request has not changed since its initiation
3. Application of the appropriate authorization procedures
4. Reexamination of previously authorized requests by the same entity



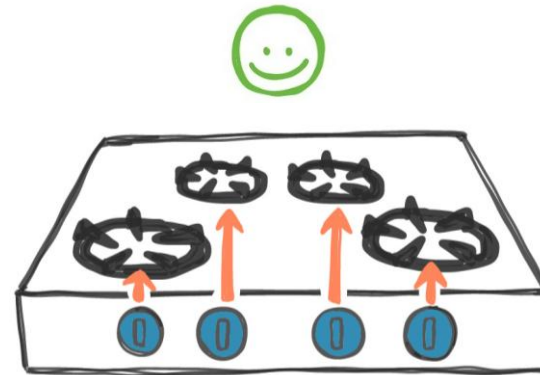
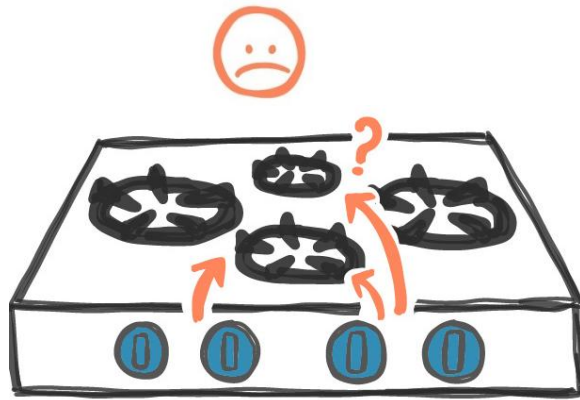
Least Common Mechanism

- This principle states that a minimum number of protection mechanisms should be common to multiple users, as shared access paths can be sources of unauthorized information exchange.
- Shared access paths that provide unintentional data transfers are known as covert channels.
- Thus, the least common mechanism promotes the least possible sharing of common security mechanisms.



Psychological Acceptability

- Psychological acceptability refers to the ease of use and intuitiveness of the user interface that controls and interacts with the cloud access control mechanisms.
- Users must be able to understand the user interface and use it without having to interpret complex instructions.

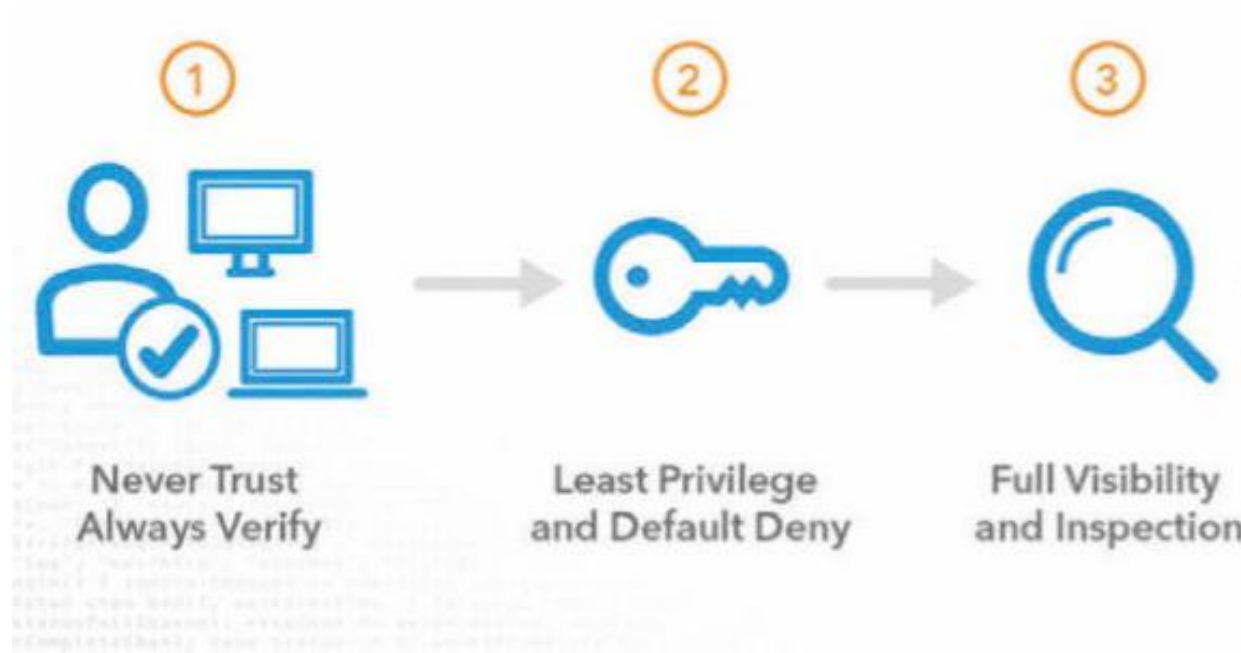


Weakest Link

- Like the old saying ‘a chain is only as strong as its *weakest link*’, the security of any system is also as good as its weakest module.
- Attackers always try to identify the most fragile part of the whole protection system in order to start their activities to dilapidate the system.
- Thus, the security system should be revised again and again to detect and resolve the weakest parts in the security chain.

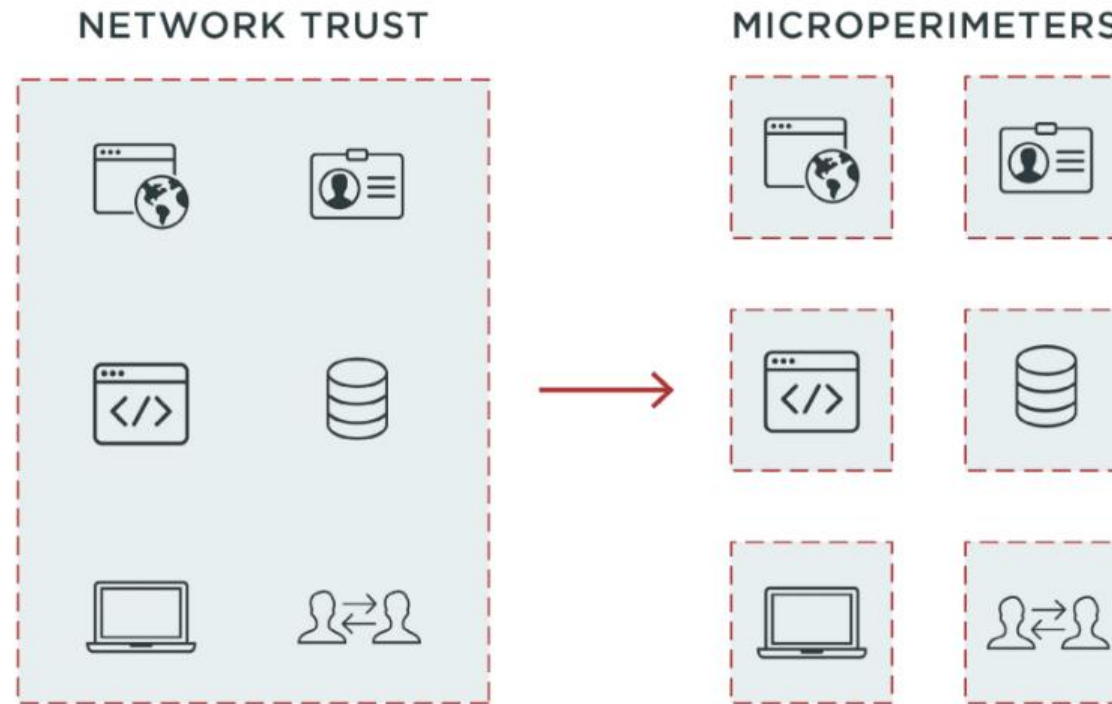


Zero Trust



Zero Trust

- Distributed security
 - Firewall
 - VPN
 - Password



Zero Trust

- <https://www.youtube.com/watch?v=PitpSDmUaXE>



Open Design Design Principle

